

Report di Laboratorio

Esercizio 4: Analisi del Traffico HTTP e HTTPS

con tcpdump e Wireshark

Autore: Team Akatsuki

Studenti: Leonardo Onori, Nicola Madonna, Alex Tarantino,
Lorenzo Rizzuti, Donato Barbetta

Corso: Cybersecurity and Ethical Hacking

Ambiente di laboratorio: VM CyberOps Workstation (analyst)

Data: 07 Settembre 2026

1. Obiettivi e Contesto

L'esercizio ha l'obiettivo di analizzare, tramite cattura pacchetti (tcpdump) e ispezione con Wireshark, le differenze pratiche tra traffico web trasmesso in HTTP (non cifrato) e traffico trasmesso in HTTPS (cifrato tramite TLS). Il laboratorio si articola in due parti:

- **Parte 1** — Cattura e visualizzazione del traffico HTTP
- **Parte 2** — Cattura e visualizzazione del traffico HTTPS

HTTP è un protocollo a livello applicativo che trasmette i dati senza alcuna protezione crittografica: chiunque intercetti il traffico di rete può leggerne il contenuto in chiaro. HTTPS, al contrario, applica la crittografia tramite TLS/SSL e l'uso di certificati digitali, rendendo i dati illeggibili a un osservatore esterno. È tuttavia importante sottolineare che l'uso di HTTPS garantisce esclusivamente la riservatezza del canale di comunicazione, non l'affidabilità del sito: anche attori malevoli utilizzano comunemente HTTPS per mascherare le proprie attività.

Ambiente e risorse utilizzate

Macchina virtuale CyberOps Workstation (utente `analyst`), interfaccia di rete `enp0s3` (indirizzo IP 10.0.2.15/24), tool `tcpdump` per la cattura pacchetti e **Wireshark** per l'analisi.

2. Parte 1 — Cattura e Analisi del Traffico HTTP

2.1 Identificazione dell'interfaccia di rete

Tramite il comando `ip address` è stata identificata l'interfaccia di rete attiva:

```
4: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP>  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic enp0s3  
        link/ether 08:00:27:2f:87:a7
```

2.2 Avvio della cattura e nota metodologica

È stata avviata la cattura del traffico con il comando:

```
sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap
```

Nota metodologica: il sito HTTP indicato originariamente dalla traccia (`testphp.vulnweb.com`) è risultato irraggiungibile durante l'esecuzione del laboratorio (timeout sulla porta 80, confermato con `curl -I` e `ping`, mentre la risoluzione DNS funzionava correttamente — probabile indisponibilità temporanea del server pubblico). È stato quindi utilizzato un sito equivalente della stessa famiglia di target di test Acunetix, `testaspnet.vulnweb.com/login.aspx`, anch'esso servito in HTTP puro ("Not Secure"), che garantisce lo stesso obiettivo didattico: osservare la trasmissione di credenziali in chiaro.



Figura 1 — Pagina di login HTTP (testaspnet.vulnweb.com), sito "Not Secure" usato in sostituzione.

2.3 Generazione del traffico

Sono state inserite delle credenziali di test nel form di login (username/password "admin"/"admin") e inviato il form; il tentativo di autenticazione non è rilevante ai fini dell'esercizio, poiché l'obiettivo è osservare il pacchetto POST generato dal browser, indipendentemente dall'esito del login. La cattura è stata quindi fermata con CTRL+C, ottenendo il seguente riepilogo:

```
26361 packets captured
26361 packets received by filter
0 packets dropped by kernel
```

2.4 Analisi in Wireshark

Il file httpdump.pcap è stato aperto in Wireshark e filtrato con l'espressione http, individuando quattro pacchetti **POST /login.aspx** di tipo `application/x-www-form-urlencoded`:

26050	22633	864389	10.0.2.15	44.238.29.244	HTTP	1871 POST /login.aspx HTTP/1.1	(application/x-www-form-urlencoded)
26142	22645	349736	10.0.2.15	44.238.29.244	HTTP	1871 POST /login.aspx HTTP/1.1	(application/x-www-form-urlencoded)
26224	22676	673613	10.0.2.15	44.238.29.244	HTTP	1871 POST /login.aspx HTTP/1.1	(application/x-www-form-urlencoded)
26329	22745	621398	10.0.2.15	44.238.29.244	HTTP	1874 POST /login.aspx HTTP/1.1	(application/x-www-form-urlencoded)

Figura 2 — Pacchetti POST /login.aspx filtrati in Wireshark (filtro: http).

Espandendo la sezione **HTML Form URL Encoded** del pacchetto POST, i dati del form sono visibili interamente in chiaro:

3. Parte 2 — Cattura e Analisi del Traffico HTTPS

3.1 Cattura del traffico

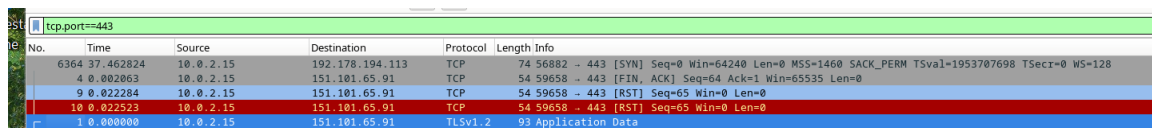
È stata avviata una nuova cattura dedicata al traffico HTTPS:

```
sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap
```

È stato quindi generato traffico HTTPS navigando su `www.netacad.com` e accedendo alla pagina di login (Cisco OneID). Si è osservato che l'URL nella barra degli indirizzi viene automaticamente presentato con il prefisso `https://` e il lucchetto di connessione sicura, a conferma dell'uso di HTTPS da parte del sito. La cattura è stata poi interrotta con CTRL+C.

3.2 Analisi in Wireshark

Il file `httpsdump.pcap` è stato aperto in Wireshark e filtrato con l'espressione `tcp.port==443`:



No.	Time	Source	Destination	Protocol	Length	Info
6364	37.462824	10.0.2.15	192.178.194.113	TCP	74	56882 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=1953707698 TSecr=0 WS=128
4	0.002063	10.0.2.15	151.101.65.91	TCP	54	59658 → 443 [FIN, ACK] Seq=64 Ack=1 Win=65535 Len=0
9	0.022284	10.0.2.15	151.101.65.91	TCP	54	59658 → 443 [RST] Seq=65 Win=0 Len=0
10	0.022523	10.0.2.15	151.101.65.91	TCP	54	59658 → 443 [RST] Seq=65 Win=0 Len=0
1	0.000000	10.0.2.15	151.101.65.91	TLSv1.2	93	Application Data

Figura 4 — Traffico sulla porta 443 filtrato in Wireshark (filtro: `tcp.port==443`).

Tra i pacchetti visualizzati, quelli di tipo **TLSv1.2 — Application Data** sono quelli contenenti i dati applicativi veri e propri (le altre righe sono solo pacchetti di apertura/chiusura della connessione TCP: SYN, FIN/ACK, RST). Selezionando un pacchetto Application Data ed espandendo la sezione **Transport Layer Security** si ottiene:

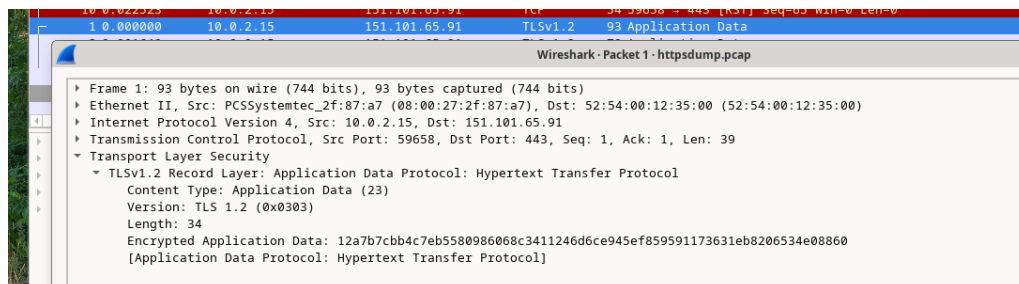


Figura 5 — Sezione TLS espansa: dati applicativi cifrati (Encrypted Application Data).

Risultato — cosa ha sostituito la sezione HTTP presente nella cattura precedente: al posto della sezione "Hypertext Transfer Protocol" con i campi leggibili, compare la sezione **Transport Layer Security**, con il campo Encrypted Application Data contenente una sequenza esadecimale (es. `12a7b7cbb4c7eb5580986068c341124...`) priva di significato leggibile.

Risultato — i dati dell'applicazione sono in formato plaintext o leggibile? No. A differenza della cattura HTTP, dove username e password erano visibili in chiaro, qui il contenuto del pacchetto è interamente cifrato da TLS e risulta illeggibile senza la chiave di decifratura, che solo client e server legittimi possiedono.

4. Confronto HTTP vs HTTPS

Aspetto	HTTP (Parte 1)	HTTPS (Parte 2)
Protocollo di trasporto	HTTP in chiaro	TLS 1.2
Contenuto visibile in Wireshark	tbUsername = "admin" tbPassword = "admin" (in chiaro)	Encrypted Application Data: sequenza esadecimale illeggibile
Leggibilità dei dati	Completa, da chiunque intercetti il traffico	Nulla, senza chiave di decifratura
Sezione visibile in Wireshark	Hypertext Transfer Protocol + HTML Form URL Encoded	Transport Layer Security (TLSv1.2 Record Layer)

5. Domande di Riflessione

1. Quali sono i vantaggi dell'uso di HTTPS invece di HTTP?

HTTPS garantisce **riservatezza** dei dati scambiati, cifrandoli tramite TLS in modo che un eventuale intercettatore (ad esempio su una rete Wi-Fi condivisa o tramite un attacco man-in-the-middle) non possa leggerne il contenuto, come invece dimostrato nella Parte 1 dell'esercizio con credenziali visibili in chiaro. Offre inoltre **integrità** dei dati, impedendo che vengano alterati durante il transito senza che ciò venga rilevato, e **autenticazione del server** tramite certificati digitali, che permette al client di verificare di star comunicando con il server legittimo e non con un impostore.

2. Tutti i siti web che usano HTTPS sono considerati affidabili?

No. HTTPS garantisce esclusivamente che la comunicazione tra client e server sia cifrata e non intercettabile, ma non certifica in alcun modo l'affidabilità, l'onestà o le intenzioni del gestore del sito. Un certificato TLS può essere ottenuto gratuitamente e con relativa facilità anche da attori malevoli, che utilizzano comunemente HTTPS per mascherare siti di phishing o altre attività dannose, sfruttando la percezione (errata) che il lucchetto nel browser equivalga a "sito sicuro" in senso generale. La sicurezza del canale (HTTPS) e l'affidabilità del contenuto/gestore sono due aspetti distinti.

6. Conclusioni

L'esercizio ha dimostrato in modo pratico e diretto la differenza sostanziale tra traffico HTTP e HTTPS: nel primo caso, l'analisi con Wireshark ha permesso di leggere in chiaro le credenziali inserite in un form di login, evidenziando il rischio concreto di intercettazione dei dati su reti non protette; nel secondo caso, lo stesso tipo di analisi sullo stesso tipo di traffico applicativo ha restituito unicamente dati cifrati e illeggibili, grazie alla protezione offerta da TLS. L'esercizio ha inoltre permesso di riflettere sul fatto che l'uso di HTTPS, pur essendo una condizione necessaria per la sicurezza delle comunicazioni web, non è di per sé garanzia di affidabilità del sito visitato.